Política de Proteção de Dados (LGPD) — Apex Group · Q2-2026

Apex Group · Documento normativo confidencial · uso interno

Comitê LGPD Apex Group

Q2-2026

[APEX GROUP] Política Corporativa de Proteção de Dados Pessoais (LGPD)

Documento normativo confidencial · uso interno

Versão `v4.2` · Revisão anual `Q2-2026` · Próxima revisão obrigatória `Q2-2027`

Aprovação: - Carla — CFO Apex Group e Encarregada (DPO) formal - Bruno — CTO Apex Group - Lia — Head de Atendimento corporativo - Comitê Executivo Apex Group (sessão Q2-2026)

Página 1 — Escopo, base legal e governança

1.1 Objeto

Este documento estabelece as diretrizes corporativas vinculantes para o tratamento de dados pessoais no Apex Group Participações S.A., CNPJ 12.345.678/0001-90, holding varejista brasileira com 12 marcas controladas (5 em produção: Apex Mercado, Apex Tech, Apex Moda, Apex Casa e Apex Logística), 340 lojas físicas, ~8.000 colaboradores diretos, ~12.400 colaboradores no histórico das últimas 12 anuidades, ~14,2 milhões de cadastros B2C ativos e ~38.700 lojistas B2B cadastrados.

A política aplica-se a toda operação de tratamento — coleta, produção, recepção, classificação, utilização, acesso, reprodução, transmissão, distribuição, processamento, arquivamento, armazenamento, eliminação, avaliação, controle, modificação, comunicação, transferência, difusão e extração — conforme definida no Art. 5, X da Lei 13.709/2018.

A política tem força normativa interna equivalente a regulamento, vincula colaboradores, terceirizados, estagiários, jovens aprendizes e operadores contratados, e descumprimentos sujeitam-se ao Código de Conduta Apex e às sanções administrativas previstas no contrato individual de

trabalho ou termo equivalente.

1.2 Base legal e regulatória

A construção desta política toma como referência o seguinte arcabouço normativo brasileiro:

- **Lei 13.709/2018 (LGPD)** — vigência plena desde 18/09/2020; sanções administrativas em vigor desde 01/08/2021
- **Decreto 10.474/2020** — estrutura regimental da Autoridade Nacional de Proteção de Dados (ANPD)
- **Resolução CD/ANPD nº 1/2021** — regulamento interno da Autoridade
- **Resolução CD/ANPD nº 2/2022** — agentes de tratamento de pequeno porte (referência subsidiária; Apex Group não se enquadra, possui Encarregada formal e RIPD obrigatório)
- **Resolução CD/ANPD nº 4/2023** — dosimetria das sanções administrativas
- **Resolução CD/ANPD nº 15/2024** — procedimento e prazos de comunicação de incidentes de segurança
- **Marco Civil da Internet (Lei 12.965/2014)** — obrigatoriedade de guarda de logs de acesso a aplicações por 6 meses (Art. 15)
- **Código de Defesa do Consumidor (Lei 8.078/1990)** — dados decorrentes de relação de consumo
- **CLT — Decreto-Lei 5.452/1943** — dados trabalhistas obrigatórios
- **Decreto 8.373/2014 e Portarias Conjuntas RFB/INSS/MTb** — eSocial e seus eventos

Em matéria fiscal e tributária, dialogam ainda CTN, Decretos 9.580/2018 (RIR) e 7.212/2010 (IPI), além da legislação ICMS estadual aplicada a cada UF de operação. A interpretação prioritária em colisão aparente entre LGPD e legislação fiscal é a de que dados sob retenção fiscal mantêm prazo legal próprio, conforme Art. 7, II (obrigação legal) e Art. 16, II da LGPD.

1.3 Aplicação

Esta política aplica-se aos seguintes domínios:

- Todos os colaboradores do Apex Group, ativos ou históricos, sob qualquer regime (CLT, estagiário, jovem aprendiz, terceirizado dedicado, prestador PJ MEI)
- Fornecedores e operadores que tratem dados pessoais por conta do Apex Group sob contrato vigente com cláusulas LGPD
- Sistemas internos centrais: ERP TOTVS, plataforma de folha Senior, HelpSphere (central B2B), CRM corporativo, datalake analítico, BI corporativo, intranet, repositórios de documentos
- Sistemas externos com fluxo bidirecional de dados pessoais: Cielo, Itaú Unibanco (PIX e cobrança), Banco do Brasil (cobrança), SEFAZ estaduais, eSocial/Receita Federal, Frota.io,

parceiros last-mile (Loggi e equivalentes), Gupy ATS, Manhattan Associates WMS, Microsoft Azure (apex-helpsphere), AWS (CDN e infraestrutura) e Microsoft 365

A política convive com regulamentos setoriais específicos. A título exemplificativo: dados de transação refrigerada hortifruti ANVISA (CFR-21 brasileiro), dados de motorista profissional ANTT, dados sanitários ANS para benefícios de saúde corporativos e dados de pagamento PCI-DSS para tokenização Cielo. Em cada caso, prevalece a regra mais protetiva ao titular.

1.4 Governança e responsabilidades

Papel	Pessoa identificada	Atribuição principal
Controlador	Apex Group Participações S.A.	Decisões sobre finalidades e meios do tratamento
Encarregada (DPO)	Carla — CFO acumulando	Interlocução com ANPD e titulares (Art. 41 LGPD)
CTO	Bruno	Medidas técnicas de segurança, criptografia, log e revogação
Head de Atendimento	Lia	Operação do Art. 18 (direitos do titular) e escalações
Comitê LGPD	Carla + Bruno + Lia + Jurídico + RH + Auditoria + Comunicação	Decisões estruturais trimestrais
Auditoria Interna	Diretoria de Auditoria	Avaliação anual de adequação da acumulação Carla

A cadeia hierárquica em matéria LGPD reporta diretamente ao CEO, sem passagem prévia pelo Conselho Financeiro ou Conselho de Tecnologia, mitigador formal da acumulação CFO/DPO descrita na Página 12.

Página 2 — Bases legais aplicáveis (Art. 7 e Art. 11 LGPD)

2.1 Bases legais para dados pessoais comuns (Art. 7)

Todo tratamento de dados pelo Apex Group deve estar fundamentado em uma das dez bases legais do Art. 7 da LGPD. Não há tratamento admissível sem base legal documentada no Registro de Operações de Tratamento (ROT), de custódia da Encarregada.

A correlação entre os incisos do Art. 7 e a operação cotidiana das marcas Apex é a seguinte:

Inciso	Base legal	Aplicação típica Apex Group
I	Consentimento	Newsletter marketing, programa de fidelidade Apex+, push notification segmentado, perfilamento publicitário consentido
II	Cumprimento de obrigação legal ou regulatória	NF-e, NFC-e e CT-e (retenção 5 anos), eSocial, FGTS, INSS, IRRF, SPED Fiscal e Contribuições
III	Execução de políticas públicas	Não aplicável diretamente; subsidiário em parcerias governamentais eventuais
IV	Estudos por órgão de pesquisa	Não aplicável
V	Execução de contrato ou procedimentos preliminares relacionados	Pedido de compra B2C/B2B, contrato com lojista, contrato individual de trabalho, leasing financeiro de frota
VI	Exercício regular de direitos em processo	Defesa em processo administrativo (ANTT, ANVISA, ANPD) ou judicial
VII	Proteção da vida ou da incolumidade física	Atendimento de emergência em loja, acidente de trabalho
VIII	Tutela da saúde, exclusivamente por profissionais de saúde	Exames ocupacionais NR-7, atestados médicos, programa Apex Bem
IX	Legítimo interesse	Análise antifraude transacional, segurança patrimonial via CFTV, prevenção a perdas no chão de loja
X	Proteção do crédito	Consulta a SPC/Serasa em pedido B2B parcelado, score interno de lojista, análise de inadimplência

2.2 Bases legais para dados pessoais sensíveis (Art. 11)

Dados pessoais sensíveis — origem racial ou étnica, convicção religiosa, opinião política, filiação a sindicato ou organização de caráter religioso, filosófico ou político, dado referente à saúde ou à vida sexual, dado genético ou biométrico — exigem base legal específica do Art. 11. As mais aplicadas no Apex Group são:

- **Consentimento específico e destacado** (Art. 11, I) — adotado exclusivamente para o programa-piloto de identificação biométrica facial em 8 lojas-conceito Apex Tech (detalhado na Página 6.2)
- **Cumprimento de obrigação legal** (Art. 11, II, "a") — exames ocupacionais NR-7 do PCMSO e eventos eSocial S-2220
- **Proteção da vida** (Art. 11, II, "d") — atendimento emergencial em loja a cliente ou colaborador
- **Tutela da saúde, exclusivamente em procedimento por profissionais de saúde** (Art. 11, II, "f") — médico do trabalho terceirizado responsável pelo SOC, com prontuário em sistema próprio sem cruzamento com RH-Folha
- **Exercício regular de direitos em processo judicial** (Art. 11, II, "e") — defesa em ação trabalhista

A oposição do titular ao tratamento com base em legítimo interesse (Art. 7, IX) é exercida via canal Art. 18 e analisada em até 10 dias úteis. Em dados sensíveis com base em consentimento, a revogação é processada em até 24 horas, com eliminação imediata do dado quando técnico e juridicamente viável.

2.3 Mudança de base legal pós-coleta

Mudança de base legal após o início do tratamento é vedada, salvo em hipótese excepcional documentada, com justificativa formal arquivada no RIPD e nova comunicação ao titular pelo canal de coleta original. A Encarregada deve aprovar previamente qualquer mudança.

Exemplos típicos: migração de "consentimento" para "execução de contrato" quando relação se formaliza por contrato escrito; ou de "legítimo interesse" para "obrigação legal" quando nova regulamentação atribui caráter compulsório à coleta. Nenhuma migração foi processada no Q1-2026; histórico disponível no RIPD para auditoria.

Página 3 — Categorias de dados tratados

3.1 Visão geral por categoria de titular

O Apex Group trata quatro grandes categorias de titulares, com volumes e sensibilidades diferenciados. A tabela abaixo apresenta o panorama Q2-2026:

Categoria	Volume estimado (Q2-2026)	Sensibilidade média	Bases legais predominantes
Clientes B2C (PF)	~14,2 milhões cadastros ativos	Média	Execução de contrato + consentimento (marketing) + legítimo interesse (antifraude)
Lojistas B2B (PJ com PF vinculadas)	~38.700 CNPJs ativos	Média-Alta	Execução de contrato + obrigação legal + proteção do crédito
Colaboradores (incluindo histórico)	~8.000 ativos + ~12.400 histórico (12 anos)	Alta	Obrigação legal + execução de contrato + tutela da saúde
Fornecedores e parceiros (representantes PF)	~4.100 CNPJs	Baixa-Média	Execução de contrato

3.2 Dados de clientes B2C

O cadastro B2C consolidado serve as marcas Apex Mercado, Apex Tech, Apex Moda e Apex Casa por meio do programa de fidelidade Apex+. Categorias tratadas:

- **Cadastrais essenciais:** nome completo, CPF, data de nascimento, endereço completo, telefone celular, e-mail
- **Cadastrais opcionais (com consentimento):** RG, gênero declarado, preferências de comunicação, perfil de consumo declarado
- **Transacionais:** histórico de compras das últimas 60 meses, ticket médio por marca, lojas mais frequentadas, mix de categorias preferidas, devoluções e trocas
- **Comportamentais (legítimo interesse + opt-in opcional):** navegação no app Apex+, abertura de push notification, cliques em e-mail marketing, jornada de busca on-site

- **Financeiros tokenizados:** cartões de crédito tokenizados via Cielo, chaves PIX favoritas, histórico de pagamento por meio
- **Programa de fidelidade Apex+:** saldo de pontos, resgates, categorias de resgate, benefícios ativos

3.3 Dados de lojistas B2B

A operação B2B é majoritariamente conduzida pela Apex Logística (tenant 5) e por divisões corporativas das marcas Apex Mercado e Apex Tech. Dados tratados:

- **Cadastrais PJ:** razão social, nome fantasia, CNPJ, IE e IM quando aplicáveis, endereço fiscal, ramo de atividade conforme CNAE, regime tributário (Simples, Lucro Presumido, Lucro Real)
- **Cadastrais PF (sócio + procurador):** nome completo, CPF, e-mail corporativo, telefone, cargo na PJ
- **Financeiros:** limite de crédito interno, score Apex, histórico de pagamento, dados bancários para PIX e TED, contratos com cláusulas comerciais
- **Operacionais:** janela contratada de doca, perfil mensal de pedidos, SLA contratual, histórico de demurrage e ressarcimentos
- **Conformidade:** certidões negativas exigidas para contrato, situação cadastral na Receita Federal, comprovações de regularidade fiscal estadual

3.4 Dados de colaboradores

Categoria mais sensível em volume e profundidade. Detalhamento exaustivo na Página 5. Em síntese, abrange:

- Cadastrais (CTPS, CPF, RG, PIS/NIS, dependentes para fins fiscais e benefícios)
- Trabalhistas (admissão, salário, banco de horas, férias, ponto eletrônico, alterações contratuais)
- Financeiros (conta-salário, FGTS, INSS, IRRF, vale-transporte, vale-alimentação)
- Saúde ocupacional (PCMSO, atestados, CAT, vacinação corporativa quando aplicável)
- Sensíveis específicos (gestação, deficiência declarada para PCD, condição étnica/racial quando autodeclarada para fins do eSocial)

3.5 Dados de fornecedores

Os ~4.100 fornecedores cadastrados envolvem dados de PJ e do PF de contato comercial. Categorias:

- Cadastrais PJ (razão social, CNPJ, regime tributário, endereço)
- Cadastrais PF de contato (nome, e-mail, telefone, cargo)
- Bancários (chave PIX, conta corrente, agência para TED quando aplicável)

- Contratuais (acordos de confidencialidade — NDA, termos de fornecimento, anexos LGPD)

3.6 Inventário consolidado de dados (Data Mapping)

O Apex Group mantém inventário consolidado de tratamento de dados (Data Mapping) no datalake corporativo, sob custódia de Bruno (CTO) com auditoria semestral por amostragem do Comitê LGPD. O inventário lista, para cada finalidade de tratamento: dado tratado, base legal, sistema-fonte, sistemas de cópia, retenção, eliminação automatizada e responsável de negócio.

A próxima revisão completa do Data Mapping está agendada para Q3-2026, com publicação do extrato anonimizado no portal `privacidade.apex.com.br/transparencia` para consulta pública dos titulares.

Página 4 — Direitos do titular (Art. 18 LGPD) e fluxo SAC

4.1 Os nove direitos do titular

A LGPD confere ao titular nove direitos exercíveis a qualquer momento, sem custo, mediante requisição expressa (Art. 18). O Apex Group disponibiliza três canais oficiais:

- **Portal LGPD:** `privacidade.apex.com.br/titular` — formulário self-service com autenticação de identidade
- **E-mail da Encarregada:** `dpo@apex.com.br` — monitorado por equipe dedicada de 3 pessoas
- **HelpSphere SAC** — abertura de ticket pelo atendente humano (Diego) categoria `LGPD – Direito do Titular`

A tabela abaixo consolida prazo legal, SLA Apex Group e a pessoa responsável por decisão final em cada direito:

Inciso	Direito	SLA Apex Group	Quem decide
I	Confirmação da existência de tratamento	5 dias úteis (simplificado) ou 15 dias (completo)	Diego (executa)
II	Acesso aos dados	15 dias	Marina
III	Correção de dados incompletos, inexatos ou desatualizados	10 dias	Diego (cadastral) / Marina (transacional)
IV	Anonimização, bloqueio ou eliminação	15 dias	Marina + Carla (validar retenção legal)
V	Portabilidade a outro fornecedor	15 dias (formato CSV/JSON estruturado)	Marina
VI	Eliminação dos dados tratados com consentimento	15 dias (sujeito a retenção legal)	Marina + Carla
VII	Informação sobre uso compartilhado	10 dias	Marina
VIII	Informação sobre possibilidade de não fornecer consentimento e consequências	Disponível no momento da coleta	— (transparência ativa)
IX	Revogação do consentimento	Imediato (processado em até 24h)	Diego (executa)

4.2 Fluxo operacional na HelpSphere

A operação de Art. 18 segue cinco etapas padronizadas:

1. **Diego (Tier 1)** recebe a requisição pelo canal escolhido pelo titular e abre ticket categoria `LGPD – Direito do Titular` com subcategoria igual ao inciso solicitado (ex.: `IV – Eliminação`).
2. **Validação de identidade:** Diego solicita CPF + dois dados adicionais cruzados — pedido prévio, endereço, e-mail cadastrado ou telefone. Em caso de inconsistência, escala para Marina.
3. **Marina (Tier 2)** recebe automaticamente após validação de identidade e executa o fluxo correspondente conforme tabela 4.3. Marina tem acesso a CRM, ERP TOTVS, datalake e Preference Center.
4. **Escalação para Lia (Head Atendimento)** em casos: vínculo trabalhista do titular como colaborador, dados sensíveis envolvidos, suspeita de fraude na requisição (ex.: 3 tentativas

falhas de validação), pedido de eliminação com retenção legal vigente.

5. **Notificação à Carla (Encarregada)** em três hipóteses: prazo legal extrapolado, recusa fundamentada do direito, requisição vinda de ofício da ANPD.

4.3 Mapa rápido por direito solicitado

Direito	Quem decide	Sistema-fonte principal	Tempo médio realizado Q1-2026
Acesso (Inciso II)	Marina	Datalake corporativo + ERP TOTVS	9 dias úteis
Correção cadastral (III)	Diego	CRM	1 dia útil
Correção transacional (III)	Marina	ERP TOTVS	6 dias úteis
Eliminação (IV/VI)	Marina + Carla	Pipeline de descarte automatizado	13 dias úteis
Portabilidade (V)	Marina	API de exportação Apex+	11 dias úteis
Revogação consentimento (IX)	Diego	Preference Center	4 horas

4.4 Recusa fundamentada

A recusa de qualquer direito do titular exige fundamentação documentada por escrito, assinada por Carla (Encarregada) e arquivada por 5 anos. Hipóteses comuns de recusa fundamentada:

- Dado sob retenção legal vigente (ex.: NF-e emitida em nome do titular com retenção fiscal de 5 anos não pode ser eliminada antes desse prazo)
- Dado já anonimizado de forma irreversível (não há como reverter para corrigir)
- Requisição abusiva — múltiplas requisições idênticas em prazo inferior a 30 dias sem motivo legítimo
- Risco demonstrado de fraude (terceiro tentando exercer direito alheio)

Em todas as hipóteses, o titular recebe comunicação formal explicando a recusa, base legal aplicada e caminhos disponíveis para recorrer (ANPD, Poder Judiciário).

4.5 Métricas trimestrais

A Encarregada publica trimestralmente, em sessão fechada do Comitê Executivo, métricas de Art. 18:

- Volume de requisições por inciso
- SLA médio realizado
- Taxa de recusa fundamentada
- Reclamações ANPD recebidas

No Q1-2026 foram processadas 412 requisições, com taxa de cumprimento dentro do SLA de 97,3% e zero comunicação da ANPD.

Página 5 — Dados de colaboradores (RH)

5.1 Ciclo de vida do dado trabalhista

O tratamento de dados de colaboradores acompanha o ciclo de vida do vínculo trabalhista. A tabela abaixo consolida os momentos, dados, base legal e sistema-fonte:

Momento	Dados coletados	Base legal	Sistema
Pré-admissão (entrevista)	Currículo, referências profissionais, autodeclarações	Procedimentos preliminares (Art. 7, V)	Gupy ATS
Admissão	CTPS, CPF, RG, PIS/NIS, dependentes, conta-salário, contrato assinado	Obrigação legal (CLT) + execução de contrato	ERP TOTVS + eSocial S-2200
Vigência	Ponto eletrônico, banco de horas, férias, salário, benefícios, alterações contratuais	Execução de contrato + obrigação legal	TOTVS RM + Senior Folha
Saúde ocupacional	Exames admissionais, periódicos, demissionais, retorno ao trabalho, mudança de função (NR-7)	Tutela da saúde (Art. 11, II, "f")	eSocial S-2220 + prontuário SOC do médico terceirizado
Acidente	CAT — Comunicação de Acidente do Trabalho	Obrigação legal (Art. 169 CLT + INSS)	eSocial S-2210 (até 24h úteis)
Demissão	Termo de rescisão, homologação, FGTS, multa rescisória, exames demissionais	Obrigação legal	eSocial S-2299
Pós-vínculo	Dados retidos por obrigação legal (folha, FGTS, IRRF)	Obrigação legal	Arquivo morto + datalake

5.2 Eventos do eSocial mais relevantes

O Apex Group transmite mensalmente cerca de ~840 eventos eSocial considerando admissões, alterações, afastamentos e desligamentos da base de 8.000 colaboradores ativos. Os eventos mais relevantes para LGPD:

- **S-1000** — Informações do Empregador (cadastrais do Apex Group)
- **S-2200** — Admissão do Trabalhador
- **S-2205** — Alteração de Dados Cadastrais
- **S-2206** — Alteração de Contrato (cargo, salário, jornada)
- **S-2210** — Comunicação de Acidente de Trabalho (CAT) — até 24h úteis

- **S-2220** — Monitoramento da Saúde do Trabalhador (PCMSO/NR-7)
- **S-2230** — Afastamento Temporário (gestação, licença médica, licença sem remuneração)
- **S-2298** — Reintegração
- **S-2299** — Desligamento

Caso real: **TKT-38** (Apex Moda) — promoção de Vendedor Pleno para Coordenador cadastrada em 02/04, evento S-2206 rejeitado pelo eSocial com mensagem "ocorrência de período já transmitido". Investigação identificou duplicidade de envio causada por reprocessamento do provedor Senior. O caso foi tratado como falha técnica sem comprometimento de confidencialidade, portanto classificado N1 conforme escala de incidentes (Página 11). O dado pessoal sensível (cargo, salário) não foi exposto. O ticket permaneceu na categoria `Operacional/Provedor` sem virar incidente LGPD.

5.3 Acesso a dados de colaboradores

O Apex Group aplica o princípio do menor privilégio (need-to-know) com segregação por papel:

- **Gestor direto:** dados operacionais (escala, banco de horas, ponto, férias agendadas) em modo leitura. Sem acesso a salário individual de subordinado fora do reporte hierárquico.
- **RH-Folha:** todos os dados trabalhistas em leitura e escrita, com log de auditoria imutável de cada alteração.
- **Saúde ocupacional:** apenas dados de saúde dos colaboradores sob sua responsabilidade clínica, em sistema SOC segregado do RH. O resultado simplificado ("apto", "inapto", "apto com restrição") chega ao RH-Folha; o detalhe clínico não.
- **Comitê de Ética:** acesso pontual durante investigação interna, com registro em log de auditoria imutável e retenção de 5 anos. Acesso é justificado, datado e identificado.
- **CTO e CFO:** sem acesso operacional ao prontuário individual de colaborador; apenas dashboards agregados anonimizados (turnover por departamento, headcount, custo médio de folha).

Caso real: **TKT-39** (Apex Casa) — canal de ética recebeu denúncia anônima sobre supervisor da loja Berrini por suposto assédio moral. Investigação confidencial pelo Comitê de Ética seguiu protocolo: prazo de 30 dias, acesso a dados de RH e ponto sob log de auditoria, oitiva de testemunhas com termo de confidencialidade. O denunciado teve direito ao contraditório após etapa instrutória, com prazo de 5 dias úteis para manifestação. Coordenação interna entre RH, Compliance e Jurídico em curso. Prazos legais respeitados.

5.4 Adiantamentos, banco de horas e benefícios

Movimentações financeiras do colaborador são especialmente sensíveis e seguem registro auditável.

- **Adiantamento salarial:** até 30% do líquido sem análise especial (somente aprovação gerente direto); acima disso requer aprovação gerente regional + RH. **TKT-36** (Apex Mercado, repositor de loja pedindo 40% para cirurgia da mãe) seguiu o fluxo: aprovação gerente regional + RH em 2 dias úteis, encaminhamento de cobertura do benefício saúde em paralelo. Dado financeiro do colaborador acessado por RH-Folha + gerente regional, com log no TOTVS RM retido por 5 anos.
- **Banco de horas:** convenção coletiva (CCT do varejo SP) limita saldo positivo em 60 horas. **TKT-33** (Apex Moda, operadora de caixa com 142h) extrapolou o limite em 82h, exigindo decisão por compensação (escala de folgas em 60 dias) ou pagamento como hora extra acrescida de 50%. Decisão tomada pela coordenadora da loja Vila Olímpia após validação RH. Dado de jornada acessado apenas por gestor direto e RH-Folha, retenção 30 anos pós-rescisão (FGTS).
- **Reembolso de treinamento: TKT-32** (Apex Tech) ilustrou caso de prova AWS Solution Architect (R$ 2.400) com aprovações OK desde 22/03, travada em "aguardando processamento" por 45 dias. Investigação de causa-raiz identificou backlog na fila do financeiro corporativo após mudança de processo. Dado financeiro (NF do treinamento + comprovante de aprovação) tratado com base legal "execução de contrato" (cláusula de treinamento técnico no contrato) + "obrigação legal fiscal" (NF retida 5 anos).
- **Licença-paternidade: TKT-34** (Apex Casa, designer de interiores) — Apex Casa não é optante do programa Empresa Cidadã, portanto licença de 5 dias úteis CLT + até 5 adicionais via banco de horas. Apex Mercado, Apex Tech e Apex Moda concedem 20 dias úteis (5 CLT + 15 Empresa Cidadã). Certidão de nascimento do filho retida no eSocial por vínculo + 30 anos.
- **Exit interview: TKT-37** (Apex Tech, vendedor com 3,2 anos pedindo desligamento) — feedback consolidado em relatório trimestral anonimizado, sem identificação individual. Principais motivos identificados pela rodada Q1-2026: oferta salarial 32% maior em concorrente + maior flexibilidade de horário.

Página 6 — Dados sensíveis (Art. 11 LGPD)

6.1 Dados de saúde — origem e tratamento

Dados de saúde constituem a maior fração de dados sensíveis tratados pelo Apex Group. Origens principais:

- **Exames ocupacionais (PCMSO/NR-7):** admissional, periódico (anual para a maior parte das funções; semestral para motoristas profissionais e operadores de empilhadeira), demissional, retorno ao trabalho após afastamento maior que 15 dias, mudança de função para atividade com risco distinto. **TKT-40** (Apex Logística) levantou 12 motoristas com exames vencendo nos 30 dias seguintes (toxicológico + audiometria + clínico). Médico do trabalho terceirizado tem

capacidade de 4 exames/dia, conforme janela `Seg-Sex 08h-12h` documentada no `faq_horario_atendimento.pdf`. Agendamento foi feito com antecedência para evitar bloqueio operacional por motorista sem ASO válido.

- **Atestados médicos:** apresentados para justificar ausência (com ou sem CID-10 conforme decisão do titular — o Apex aceita ambos os formatos). Atestados ficam custodiados no SOC do médico do trabalho; o RH-Folha recebe apenas registro de afastamento com período.
- **CAT — Comunicação de Acidente do Trabalho: TKT-35** (Apex Logística, motorista cortou a mão em descarga com lâmina de stretch) — atendimento UPA com 2 pontos e liberação. Evento configura acidente de trabalho conforme Lei 8.213/1991. CAT emitida no eSocial S-2210 em até 24h úteis. Investigação de causa-raiz solicitada (uso de EPI), com revisão de procedimento de treinamento na operação de descarga.
- **Programa Apex Bem:** check-up anual corporativo facultativo, com consentimento específico de cada participante. Resultados ficam exclusivamente na empresa terceirizada de medicina ocupacional; Apex recebe somente relatório agregado anonimizado de indicadores populacionais (prevalência de hipertensão, índice de massa corporal médio etc.) para construir políticas de bem-estar.

Segregação técnica de dados de saúde: - Armazenamento em ambiente isolado: SOC do médico do trabalho terceirizado, com integração eSocial via Service Bus criptografado AES-256 - Acesso restrito a profissional de saúde licenciado (médico do trabalho + enfermagem do SOC) - Gestor direto recebe apenas resultado simplificado ("apto", "apto com restrição", "inapto") - RH-Folha recebe data e período de afastamento, sem detalhe clínico - Logs imutáveis com retenção de 20 anos pós-rescisão (NR-7 item 7.4.5)

6.2 Biometria em PDV — programa-piloto Apex Tech

Apex Tech opera projeto-piloto de identificação biométrica facial em 8 lojas-conceito: Iguatemi, Morumbi, Faria Lima, Berrini, JK Iguatemi, Pátio Higienópolis, Eldorado e Cidade Jardim. Objetivos do piloto: personalização da experiência de cliente Apex+ identificado e prevenção a perdas com correlação a ocorrências passadas registradas.

Salvaguardas LGPD aplicadas:

- **Base legal:** consentimento específico e destacado (Art. 11, I) — opt-in expresso em cada loja, sem dark pattern
- **Coleta:** câmeras dedicadas em postos identificados, com aviso visível na entrada da loja e cartaz dedicado no posto (cartaz NR-26 ao lado da sinalização LGPD)
- **Armazenamento:** o sistema converte a imagem em hash criptográfico (embedding facial), descarta a imagem original e armazena apenas o hash em Azure Key Vault dedicado com criptografia AES-256. A imagem facial bruta nunca é persistida.
- **Retenção:** 90 dias para perfilamento Apex+; eliminação imediata se titular revogar consentimento via `privacidade.apex.com.br/biometria`

- **Compartilhamento:** vedado. Biometria não é repassada a terceiros sob nenhuma hipótese, nem mesmo a parceiros intra-grupo (Apex Mercado, Apex Moda, Apex Casa). Cada marca opera consentimento próprio.
- **Transferência internacional:** vedada. Todo o pipeline biométrico roda exclusivamente na região Brasil Sul (Azure) sem replicação geo-redundante para fora do território nacional.

Avaliação de Impacto (RIPD): RIPD específico para o programa-piloto biométrico foi elaborado por Bruno e aprovado por Carla em Q1-2026. Revisão semestral. Indicadores monitorados: taxa de identificação correta, taxa de falso-positivo, volume de revogação de consentimento, reclamações de titular.

6.3 Dados de menores (Art. 14 LGPD)

O Apex Group trata dados de menores em três hipóteses estritas:

- **Cadastros de jovens aprendizes:** vínculo com base na Lei 10.097/2000 (cota de aprendizes) e CLT Art. 428. Base legal: execução de contrato + obrigação legal. Apex Group mantém ~280 jovens aprendizes ativos em Q2-2026 em diversas funções administrativas e de retaguarda.
- **Dependentes de colaboradores:** para fins de vale-creche, plano de saúde corporativo e dedução IRRF de dependentes. Base legal: consentimento do responsável legal + interesse superior do menor (Art. 14, §1º). Dados retidos: nome, CPF, data de nascimento, parentesco. Sem dados sensíveis dos dependentes.
- **Promoções com participação infantil:** campanhas Apex Moda Dia das Crianças e Apex Tech volta às aulas com possibilidade de cadastro de crianças. Vedado coletar dados além do estritamente necessário (nome e idade da criança, sem CPF). Consentimento expresso de pelo menos um dos pais ou responsável legal documentado.

Vedações específicas: - Marketing comportamental dirigido a menores: vedado - Perfilamento publicitário com dados de menores: vedado - Transferência internacional de dados de menores: vedada - Compartilhamento com terceiros para fins externos: vedado

6.4 Outras categorias sensíveis

- **Filiação sindical:** registrada no eSocial quando aplicável (Art. 11, II “a” — obrigação legal). Acesso restrito ao RH-Folha.
- **Convicção religiosa:** tratada apenas se autodeclarada para fins específicos (ex.: dispensa em feriado religioso documentada em CCT). Sem perfilamento.
- **Origem racial/étnica:** autodeclaração opcional do colaborador para fins de eSocial e indicadores de diversidade. Dado sensível tratado com base legal “obrigação legal”.

A política Apex Group veda expressamente decisões automatizadas exclusivamente com base em dados sensíveis, em conformidade com o Art. 20 da LGPD. Decisões com efeito de admissão, promoção, demissão ou aplicação de medida disciplinar têm intervenção humana de gestor ou

Comitê definido em política específica.

Página 7 — Política de gestação e licença-maternidade

7.1 Antecedente legal integrado

A política Apex Group de gestação e licença-maternidade integra três conjuntos normativos:

- **CLT Art. 391-A** — estabilidade da gestante desde a confirmação da gravidez até cinco meses após o parto, independentemente do conhecimento do empregador no momento da admissão
- **CLT Art. 392** — licença-maternidade de 120 dias com salário integral pago pelo empregador e compensado posteriormente em GRRF/INSS
- **CLT Art. 392-A** — extensão equivalente à licença adotante, com modulação por idade da criança adotada
- **Lei 11.770/2008 — Programa Empresa Cidadã** — prorrogação facultativa de 60 dias adicionais à licença-maternidade (total de 180 dias) e de 15 dias úteis adicionais à licença-paternidade. Apex Mercado, Apex Tech e Apex Moda são optantes; Apex Casa e Apex Logística não são (referência **TKT-34** — Apex Casa, designer de interiores, recebeu orientação 5 dias úteis CLT com até 5 adicionais via banco de horas).
- **LGPD Art. 11, II "f"** — proteção da saúde em procedimento por profissional de saúde

7.2 Confirmação da gravidez e troca de turno — fluxo padronizado

Casos como **TKT-31** (Apex Mercado, operadora de caixa do turno noturno apresentou atestado de gravidez de risco recomendando turno diurno) seguem o seguinte protocolo formal:

1. **Diego (Tier 1)** recebe ticket pelo HelpSphere SAC ou pelo gestor direto da loja
2. Identifica que se trata de solicitação relacionada a gestação e **escala automaticamente para RH-Folha** sem deixar em fila aberta visível a outros atendentes
3. **RH-Folha** solicita atestado médico ao titular, recebido em sigilo sob custódia de profissional de saúde (médico do trabalho)
4. **Coordenação da loja** é informada apenas do resultado: necessidade de troca de turno ou não, sem qualquer detalhe clínico (não fica sabendo que se trata de gravidez de risco, só que a colaboradora está apta a trabalho diurno e tem restrição de turno noturno)

5. **Rebalanceamento de escala** em até 5 dias úteis pelo coordenador de loja, com apoio do RH
6. **Registro no eSocial S-2230** (afastamento temporário) somente se aplicável; troca de turno por si só não exige envio do evento
7. **Comunicação ao Comitê LGPD** apenas em caso de incidente (ex.: vazamento da condição clínica a colegas) — não é o caso padrão

7.3 Dados tratados durante a gestação

Dado	Quem acessa	Base legal	Retenção
Atestado de gravidez	Médico do trabalho + RH-Folha (acesso segregado, sem detalhe clínico para RH-Folha além de "apta com restrição")	Art. 11, II "f"	Até 5 anos pós-licença (eSocial) + 20 anos pós-rescisão (NR-7)
Data prevista de parto (DUM)	RH-Folha + gestor direto (apenas a data)	Art. 7, V (execução de contrato)	Idem
Restrições médicas	Médico do trabalho (com detalhe clínico) + gestor direto (apenas "apto com restrição: trabalho diurno")	Art. 11, II "f"	Vinculado ao prontuário SOC
Filho nascido (certidão para dependente)	RH-Folha + área de benefícios	Obrigação legal (FGTS, INSS, vale-creche)	Vínculo + 30 anos
Comprovante de licença	RH-Folha + eSocial	Obrigação legal	30 anos

7.4 Licença-paternidade

A política se diferencia por marca empregadora:

- **Apex Mercado, Apex Tech, Apex Moda** (optantes Empresa Cidadã): 20 dias úteis (5 CLT + 15 Empresa Cidadã)
- **Apex Casa, Apex Logística** (não optantes): 5 dias úteis CLT padrão + até 5 dias adicionais via banco de horas, mediante solicitação do colaborador e aprovação do gestor direto

O **TKT-34** (Apex Casa, designer de interiores com filho previsto para 15/05) ilustra o segundo cenário. Comunicado oficial de 5 dias úteis CLT foi emitido pelo RH; titular optou por usar 5 dias adicionais do seu saldo de banco de horas. RH atualizou cartilha interna para reforçar a orientação a

outros titulares.

7.5 Retorno e adaptação pós-licença

A política Apex Group reforça os direitos previstos em CLT:

- **Dois intervalos diários de 30 minutos para amamentação até os 6 meses do filho** (CLT Art. 396), com flexibilidade de divisão (ex.: 1h corrida em vez de 2 × 30min) se acordado com gestor direto
- **Sala de apoio à lactação** disponível no CD-Cajamar e na sede São Paulo capital, com geladeira dedicada para conservação de leite materno
- **Adaptação de jornada gradual** nos primeiros 60 dias pós-retorno, conforme prescrição médica e acordo com gestor
- **Não realização de viagens** no primeiro trimestre pós-retorno, salvo concordância expressa da colaboradora

7.6 Garantia LGPD — segregação clínica

Toda a documentação clínica do ciclo gestacional, do atestado de confirmação à liberação para retorno, é armazenada exclusivamente no SOC do médico do trabalho terceirizado. RH-Folha e gestores não têm acesso a CID-10, exames pré-natais, condições clínicas específicas ou tratamentos prescritos.

Violações desse princípio configuram incidente de segurança classificado N3 (dado sensível com exposição). O fluxo de resposta a incidente (Página 11) é acionado, e o Comitê LGPD avalia consequências disciplinares conforme Código de Conduta Apex.

7.7 Estabilidade pós-licença e demissão

A estabilidade prevista no Art. 391-A da CLT é monitorada automaticamente pelo TOTVS RM, que bloqueia qualquer tentativa de demissão sem justa causa dentro do prazo (confirmação da gravidez + 5 meses após o parto). Tentativas bloqueadas geram alerta para o RH-Folha e para o Comitê LGPD, que avalia se houve tentativa de discriminação direta ou indireta.

Página 8 — Compartilhamento com terceiros (operadores)

8.1 Princípio geral

O compartilhamento de dados pessoais com terceiros pelo Apex Group ocorre exclusivamente quando:

- Existe contrato vigente entre Apex e o terceiro com cláusulas LGPD obrigatórias (modelo padronizado pela Encarregada e pelo Jurídico)
- O terceiro está caracterizado como **operador** (trata dados em nome e por conta do Apex Group, com decisão de finalidade exclusivamente do Apex) ou **controlador conjunto** (decisão de finalidade compartilhada, hipótese rara)
- O compartilhamento está mapeado no Registro de Operações de Tratamento (ROT) sob custódia da Encarregada

Compartilhamento sem contrato com cláusulas LGPD é vedado e configura incidente N2 ou superior conforme escala (Página 11).

8.2 Operadores principais

Operador	Categoria	Dados compartilhados	Base legal	Localização
Cielo	Adquirente de cartão	Cartão tokenizado, valor, CPF (B2B), CNPJ	Execução de contrato	Brasil — Barueri-SP
Itaú Unibanco	Banco PIX e cobrança	CPF/CNPJ titular, valor, chave PIX	Execução de contrato + obrigação legal Bacen	Brasil
Banco do Brasil	Cobrança boleto	Idem Itaú (caso **TKT-44** — boleto R$ 47.300 sem retorno em D+10)	Execução de contrato	Brasil
SEFAZ-SP e SEFAZ estaduais	Autoridade fiscal	Dados de NF-e/NFC-e/CT-e (CPF/CNPJ titular)	Obrigação legal	Brasil
Receita Federal — eSocial	Autoridade trabalhista	Todos os dados do colaborador trabalhista	Obrigação legal	Brasil
TOTVS	ERP SaaS	Cadastrais + transacionais + folha	Execução de contrato	Brasil — SP + Joinville
Senior Sistemas	Folha SaaS	Folha + ponto eletrônico + benefícios	Execução de contrato	Brasil
Frota.io	Roteirizador logístico	Endereço de entrega, CPF do receptor, nome	Execução de contrato	Brasil (referência **TKT-15** — webhook caiu em D-1 17h)
Loggi e parceiros last-mile	Transportadora	Endereço, telefone, CPF	Execução de contrato	Brasil (referência **TKT-20** — VPN com Loggi falhou após renewal de cert)

Operador	Categoria	Dados compartilhados	Base legal	Localização
Gupy	ATS recrutamento	Currículo, contatos, autodeclarações	Procedimentos preliminares (Art. 7, V)	Brasil
Manhattan Associates	WMS	Dados de pedido (CPF/CNPJ destinatário, endereço)	Execução de contrato	Brasil + EUA (dual-region)
AWS	CDN + infraestrutura	Logs anonimizados + objetos do app	Legítimo interesse (segurança e performance)	EUA — Virginia us-east + Brasil — SP
Microsoft Azure	apex-helpsphere + datalake	Dados de ticket + datalake corporativo	Execução de contrato	Brasil Sul + East US 2
Microsoft 365	E-mail + colaboração	E-mail corporativo + Teams + SharePoint	Execução de contrato	EUA + Irlanda
Cloudflare	Camada anti-DDoS	Logs de IP + cabeçalhos HTTP	Legítimo interesse (segurança)	Países Baixos
SPC/Serasa	Bureau de crédito	CPF/CNPJ + consulta de score	Proteção do crédito (Art. 7, X)	Brasil
Pinheiro Advogados (fictício)	Jurídico externo	Documentos de processo, dados de parte	Exercício regular de direitos (Art. 7, VI)	Brasil

8.3 Cláusulas contratuais obrigatórias

Todo contrato com operador é submetido a checagem de mínimos LGPD pelo Jurídico antes da assinatura. As cláusulas obrigatórias incluem:

- **Finalidades específicas:** descrição clara e fechada do propósito do tratamento; vedação de uso para fins distintos
- **Categorias de dados compartilhados:** lista exaustiva; ampliação requer aditamento contratual
- **Medidas técnicas e organizacionais mínimas:** criptografia em trânsito (TLS 1.2 ou superior) e em repouso (AES-256), segregação de ambientes, controle de acesso baseado em função (RBAC), log de auditoria

- **Subcontratação:** somente com anuência prévia por escrito do Apex; subcontratado herda obrigações LGPD
- **Direito de auditoria:** Apex pode auditar operador in loco ou remotamente, com aviso prévio de 30 dias, no máximo 1 vez por ano (exceto em caso de incidente)
- **Notificação de incidente:** operador deve notificar Apex em até 24h após confirmação do incidente; Apex tem 72h para decidir comunicação à ANPD se aplicável
- **Devolução ou eliminação ao fim do contrato:** operador deve devolver ou eliminar todos os dados em até 30 dias do encerramento contratual, com comprovação assinada digitalmente

8.4 Compartilhamento intra-grupo Apex

Compartilhamento entre as marcas do grupo (Apex Mercado, Apex Tech, Apex Moda, Apex Casa, Apex Logística, e as 7 marcas adicionais — ApexFashion, ApexHogar, ApexBabe, ApexFood, ApexSports, ApexBeauty, ApexFarma) tem regime próprio:

- **Cadastro Apex+ (programa de fidelidade):** consentido pelo titular no momento de adesão, com aviso explícito de compartilhamento entre marcas e finalidades
- **Dados transacionais agregados (BI):** anonimizados antes da disponibilização
- **Dados de colaborador:** restritos à marca empregadora, exceto em transferência interna formal (mudança de marca empregadora) com novo termo de aceite

Titular pode opor-se (Art. 18, §2º) ao compartilhamento intra-grupo a qualquer momento, com efeito imediato sobre comunicações comerciais e em até 5 dias úteis sobre integração de cadastro.

8.5 Vedação absoluta — venda e cessão de bases

O Apex Group **não comercializa, não aluga e não cede** bases de dados de titulares a terceiros para fins de marketing ou perfilamento externo. Esta política é cláusula pétrea da governança LGPD e não pode ser alterada por decisão executiva sem aprovação prévia do Conselho de Administração com voto unânime.

A vedação se estende a: - Venda direta de listas de e-mail, telefone, endereço ou CPF - Cessão a parceiros publicitários (ad networks, DMPs externas) - Compartilhamento com bureaus de marketing - Monetização de dados de navegação

Exceções estritas: cessão obrigatória por força de lei (eSocial, SEFAZ, ANPD) ou ordem judicial.

Página 9 — Transferência internacional de

dados (Art. 33 LGPD)

9.1 Princípio e bases para transferência

A LGPD admite transferência internacional de dados pessoais apenas nas hipóteses do Art. 33. Em Q2-2026, não há países oficialmente reconhecidos pela ANPD como possuindo nível adequado de proteção (Inciso I) — decisão pendente da Autoridade. O Apex Group opera transferência internacional fundamentando-se nas seguintes hipóteses:

- **Art. 33, II** — quando o controlador oferecer e comprovar garantias adequadas: cláusulas-padrão contratuais (SCC) adotadas pelo Apex e pelo operador, normas corporativas globais e selos de certificação reconhecidos
- **Art. 33, V** — quando a transferência for necessária para a execução de contrato do qual seja parte o titular (ex.: cliente que faz pedido pelo app, com backend em região internacional do operador)
- **Art. 33, VII** — quando o titular fornecer consentimento específico para transferência internacional

9.2 Transferências mapeadas no Registro de Operações

Destino	Operador	Categoria de dado	Volume mensal aproximado	Base legal aplicada
EUA — Virginia (us-east)	AWS CloudFront CDN	Logs anonimizados de navegação	~280 GB	Art. 33, V + cláusulas-padrão
EUA — East US 2 (Azure)	Microsoft Azure (backup geo-redundante)	Backup do apex-helpsphere	~45 GB	Art. 33, V + cláusulas-padrão
EUA + Irlanda	Microsoft 365 (Exchange + SharePoint + Teams)	E-mail corporativo + documentos + chats	~1,2 TB	Art. 33, V + cláusulas-padrão
Países Baixos	Cloudflare (anti-DDoS)	Logs de IP + cabeçalhos HTTP de tráfego web	~12 GB	Art. 33, II (legítimo interesse de segurança)
EUA (dual-region)	Manhattan Associates WMS	Dados de pedido em processamento	~80 GB	Art. 33, V + cláusulas-padrão

9.3 Salvaguardas técnicas obrigatórias

Toda transferência internacional do Apex Group respeita salvaguardas técnicas mínimas:

- **Criptografia em trânsito:** TLS 1.3 obrigatório; TLS 1.2 admitido apenas em fallback para integrações legadas mapeadas no inventário e com plano de modernização datado
- **Criptografia em repouso:** AES-256 com chaves gerenciadas em Azure Key Vault (Brasil Sul) e AWS KMS (us-east), nunca em chave compartilhada com operador
- **Pseudonimização:** dados sensíveis são pseudonimizados antes de qualquer transferência analítica (substituição de identificador direto por hash não-reversível com sal específico por finalidade)
- **Logs de acesso:** preservados por 6 meses (Marco Civil Art. 15) com retenção estendida a 12 meses para acessos a dados sensíveis
- **Segmentação de rede:** ambientes que recebem dados pessoais brasileiros isolados de ambientes globais multi-tenant do operador

9.4 Avaliação de impacto (RIPD) prévia

Toda nova transferência internacional exige RIPD aprovado pela Encarregada antes da entrada em produção. O RIPD avalia:

- Necessidade e proporcionalidade da transferência
- Categorias de dados envolvidos
- Risco ao titular (probabilidade × severidade)
- Salvaguardas técnicas e contratuais
- Plano de contingência em caso de bloqueio regulatório (ex.: invalidade da SCC)

RIPDs existentes são revistos anualmente no Q2 (próxima revisão Q2-2027) ou em qualquer alteração material (mudança de localização, novo subprocessador, mudança regulatória).

9.5 Restrições específicas

O Apex Group adota restrições mais protetivas que a LGPD admite, baseadas em decisões internas de risco:

- **Dados biométricos** (Apex Tech — programa-piloto, Página 6.2): proibida qualquer transferência internacional, mesmo anonimizada. Todo o pipeline opera exclusivamente em região Brasil Sul.
- **Dados de saúde ocupacional e CAT:** armazenados exclusivamente em servidores Brasil. Sem replicação geo-redundante internacional.
- **Dados de menores** (aprendizes, dependentes, promoções infantis): armazenamento exclusivo Brasil.
- **Dados de denúncia anônima** (canal de ética): armazenamento exclusivo Brasil.
- **Documentos de processo trabalhista em curso:** armazenamento exclusivo Brasil até trânsito em julgado.

9.6 Monitoramento contínuo

O Apex Group monitora trimestralmente decisões da ANPD, do Comitê Europeu de Proteção de Dados (CEPD) e regulações comparadas (CCPA na Califórnia, PIPL na China, PDPA em Cingapura) que possam afetar transferências em curso. Mudança regulatória material dispara revisão extraordinária do RIPD aplicável.

Página 10 — Política de retenção e descarte

10.1 Princípio da minimização

Conforme Art. 6, III da LGPD, dados pessoais devem ser retidos somente pelo tempo necessário ao cumprimento das finalidades declaradas ou da obrigação legal aplicável. Após esse prazo, é obrigatório:

- **Descarte (eliminação)** com overwrite criptográfico em datalake e exclusão lógica em sistemas operacionais, ou
- **Anonimização irreversível** com técnicas estatísticas que impeçam reidentificação razoável (k-anonimato, l-diversidade, ruído diferencial conforme aplicabilidade)

10.2 Tabela mestre de retenção

Categoria de dado	Prazo de retenção	Fundamento normativo	Sistema-fonte
NF-e, NFC-e, CT-e	5 anos após emissão	Decreto 9.580/2018 (RIR) + CTN Art. 173	SEFAZ + arquivo fiscal interno
SPED Fiscal e SPED Contribuições	5 anos	Lei 9.430/1996 + Decreto 7.212/2010	Receita Federal + ERP
eSocial — folha, FGTS, ponto	30 anos pós-rescisão	Decreto 99.684/1990 (FGTS) + CLT	eSocial + TOTVS RM
CAT — Comunicação de Acidente	30 anos	Art. 169 CLT + INSS	eSocial S-2210
PCMSO — exames ocupacionais	20 anos pós-rescisão	NR-7 item 7.4.5	SOC do médico do trabalho
Contratos comerciais B2B	Vigência + 10 anos	CCB Art. 205 + prudência comercial	Repositório jurídico
Pedidos B2C (relação de consumo)	5 anos pós fim da relação	CDC Art. 26 + prudência	ERP + CRM
Logs de acesso a sistemas	6 meses (regra geral) / 12 meses (sensíveis)	Marco Civil Art. 15 + política Apex	Microsoft Sentinel SIEM
Cliente B2C inativo (sem compra ou interação)	2 anos após última interação	LGPD princípio da necessidade	CRM (pipeline de descarte)
Marketing e perfilamento consentido	Até revogação	Art. 16, II	Preference Center
Currículos não aprovados (Gupy)	12 meses pós-processo	LGPD + política Apex	Gupy ATS
CFTV — gravação rotineira	30 dias	Legítimo interesse	NVR local + Azure Blob
CFTV — gravação com incidente registrado	180 dias	Legítimo interesse + prudência jurídica	Azure Blob com tag de retenção
Biometria PDV Apex Tech	90 dias (consentido) / imediato (revogado)	Consentimento Art. 11, I	Azure Key Vault

Categoria de dado	Prazo de retenção	Fundamento normativo	Sistema-fonte
Dados de denúncia canal de ética	Até conclusão da investigação + 5 anos	Política interna + LGPD	Sistema dedicado isolado
Dossiês ANPD (incidentes comunicados)	10 anos	Resolução CD/ANPD nº 15/2024 + prudência	Repositório Encarregada

10.3 Pipeline de descarte automatizado

O Apex Group opera pipeline automatizado de descarte sob responsabilidade técnica de Bruno (CTO):

- **Job batch noturno** em Azure Data Factory varre tabelas-alvo a cada 30 dias procurando registros que atingiram o prazo de eliminação
- **Geração de relatório de descarte** assinado digitalmente pela Encarregada Carla via Azure Information Protection
- **Eliminação física e lógica:** overwrite em datalake (3 passadas de zeros para mídias HDD legadas; soft-delete + criptografia de chave em SSD), seguido de exclusão lógica no sistema-fonte
- **Auditoria de dupla verificação** por Bruno + Carla em sample mensal de 50 registros eliminados
- **Backup geo-redundante:** rotação de 90 dias; após esse prazo, backup é eliminado ou substituído por dado agregado anonimizado mantido apenas para fins de BI

10.4 Recusa fundamentada de eliminação

O direito de eliminação (Art. 18, VI) pode ser recusado quando há retenção legal vigente. Exemplo recorrente: titular B2C solicita eliminação completa de seu cadastro. Apex deve recusar a eliminação imediata de:

- NF-e emitidas em nome do titular nos últimos 5 anos (obrigação legal fiscal)
- Pedidos com garantia legal de 90 dias ou contratual vigente (relação de consumo)
- Eventuais débitos pendentes em cobrança (exercício regular de direito)

O titular recebe comunicação formal explicando recusa, base legal aplicada, dados que serão eliminados após o prazo legal expirar (com cronograma), e caminhos de recurso (ANPD, Poder Judiciário). Após cumprido o prazo de retenção legal, o dado é eliminado em pipeline mensal de "descarte legal" sem necessidade de nova solicitação.

10.5 Anonimização como alternativa

Em situações onde a eliminação total comprometeria continuidade de obrigação legal mas o dado pode ser desidentificado, o Apex aplica anonimização irreversível. Casos típicos:

- Pesquisa de satisfação de cliente B2C antiga — anonimizada para análise agregada
- Histórico de turnover de colaboradores — anonimizado para BI de RH
- Logs de operação de sistema — anonimizados após 6 meses do prazo Marco Civil

Anonimização irreversível só é considerada efetiva quando passa por teste de reidentificação por amostragem. O Apex realiza teste anual com sample de 100 registros anonimizados, contratando consultoria externa especializada.

Página 11 — Incidentes de segurança (Art. 48 LGPD)

11.1 Definição de incidente

Para efeitos desta política, incidente de segurança é qualquer evento adverso **confirmado** relacionado a:

- **Violação de confidencialidade:** acesso indevido a dado pessoal por parte de quem não tem autorização (interno ou externo)
- **Violação de integridade:** alteração não autorizada do dado pessoal, intencional ou acidental
- **Violação de disponibilidade:** perda total ou parcial de acesso a dado pessoal por ataque (ransomware, DDoS) ou falha técnica significativa
- **Vazamento:** exposição de dado pessoal para fora do perímetro autorizado, intencional ou acidental, com ou sem evidência de uso indevido

Eventos que possam acarretar risco ou dano relevante aos titulares devem ser comunicados à ANPD em até 72 horas após o conhecimento pelo controlador, conforme Art. 48 LGPD e Resolução CD/ANPD nº 15/2024.

11.2 Classificação interna por severidade

Nível	Critério	Tempo de resposta inicial	Quem ativa
N1 — Baixo	Tentativa frustrada sem exposição, falha técnica sem comprometimento de confidencialidade	4 horas úteis	Bruno (CTO)
N2 — Médio	Exposição limitada (<100 titulares), sem dado sensível, sem evidência de uso indevido	2 horas	Bruno + Marina
N3 — Alto	Exposição ampla, OU dado sensível envolvido, OU >100 titulares, OU evidência de uso indevido	1 hora	Bruno + Lia + Carla
N4 — Crítico	Vazamento massivo (milhares de titulares), OU dado sensível + crianças, OU risco patrimonial agudo, OU ataque coordenado em curso	Imediato (15 min)	Comitê de Crise (CEO + jurídico externo)

11.3 Fluxo de resposta a incidente N3 e N4

1. **Detecção** — alerta automático do SIEM (Microsoft Sentinel) ou denúncia interna recebida em qualquer canal (compliance, ética, HelpSphere)
2. **Contenção imediata** — Bruno aciona o time de SecOps; ações típicas: bloqueio de credencial comprometida, segmentação de rede, isolamento de host, revogação de token de API. Tempo: até 1 hora.
3. **Triagem** — em até 4 horas, equipe técnica entrega estimativa preliminar: titulares afetados, categorias de dados, presença de sensíveis, vetor de ataque
4. **Decisão de comunicação ANPD** — Carla (Encarregada) avalia critério de risco relevante em até 24 horas após detecção
5. **Comunicação ANPD** — formulário oficial via sistema da ANPD em até 72 horas, mesmo que a investigação ainda esteja em curso (informação complementar pode ser enviada

posteriormente)

6. **Comunicação aos titulares** — quando ANPD determinar ou houver risco relevante (Art. 48, §2º), por canal direto (e-mail cadastrado ou correio físico) e por publicação em portal `privacidade.apex.com.br/comunicados`
7. **Postmortem** — relatório técnico completo em até 15 dias úteis pós-resolução, com causa-raiz, lições aprendidas e plano de remediação. Lições alimentam treinamento (Página 13).

11.4 Conteúdo mínimo da comunicação à ANPD

Conforme Resolução CD/ANPD nº 15/2024, a comunicação à ANPD deve conter:

- Descrição do incidente, incluindo data e horário de detecção
- Categorias de titulares afetados e número estimado
- Dados pessoais e sensíveis envolvidos
- Medidas técnicas e organizacionais de proteção em vigor antes do incidente
- Riscos relacionados ao incidente
- Medidas de mitigação adotadas e a adotar
- Justificativa de eventual atraso na comunicação (se aplicável)
- Identificação da Encarregada e canal de contato

11.5 Histórico de incidentes Q1-2026

No primeiro trimestre de 2026, o Apex Group registrou:

- **2 incidentes N2:** falha em script de notificação que expôs e-mail corporativo de 38 colaboradores em CC visível (categoria operacional, sem sensíveis); e configuração incorreta de bucket de teste em ambiente de desenvolvimento (sem dados produtivos reais, falsa positiva mas processada com rigor)
- **0 incidentes N3 ou N4**
- **0 comunicações à ANPD** (nenhum incidente atingiu critério de risco relevante)

Detalhamento completo em dossiê confidencial sob custódia de Carla, com retenção de 10 anos conforme Página 10.2.

11.6 Postmortem como ativo organizacional

Cada incidente N2+ gera postmortem público interno (com identificadores removidos) publicado na intranet `intranet.apex.com.br/lgpd/postmortems`. O objetivo é cultura de aprendizado sem culpabilização individual (blameless postmortem). Causa-raiz, decisão de mitigação e indicadores de eficácia são compartilhados com todo o time de TI, Segurança e RH.

Página 12 — Encarregada (DPO) e Comitê LGPD

12.1 Encarregada formal — Carla

Carla, CFO do Apex Group, acumula a função de Encarregada (Data Protection Officer — DPO) desde 2023, com nomeação publicizada nos canais oficiais conforme exigência do Art. 41, §1º da LGPD. A acumulação é admitida pela LGPD desde que sem conflito material de interesse.

Como mitigadores formais da acumulação, o Apex Group adota:

- **Reporte direto ao CEO em matéria LGPD**, sem passagem pelo Conselho Financeiro ou pelo Conselho de Tecnologia, segregando a cadeia decisória de proteção de dados das cadeias financeira e tecnológica
- **Comitê LGPD multidisciplinar** (Seção 12.3) com poder de veto em deliberações que conflitem com proteção de dados
- **Avaliação anual de adequação da acumulação** pela Auditoria Interna, com relatório consolidado submetido ao Comitê de Auditoria do Conselho de Administração
- **Plano de sucessão LGPD** com Encarregada substituta identificada, não publicizada externamente por sensibilidade, custodiada pelo Jurídico

Contato público: `dpo@apex.com.br`, monitorado por equipe dedicada de três pessoas que executa a triagem inicial e escala para Carla as decisões finais.

12.2 Atribuições da Encarregada (Art. 41 LGPD)

A LGPD atribui à Encarregada as seguintes funções (Art. 41, §2º):

- Aceitar reclamações e comunicações dos titulares, prestar esclarecimentos e adotar providências
- Receber comunicações da ANPD e adotar providências
- Orientar funcionários e contratados a respeito das práticas a serem tomadas em relação à proteção de dados pessoais
- Executar as demais atribuições determinadas pelo controlador ou estabelecidas em normas complementares

No Apex Group, Carla adicionalmente:

- Preside o Comitê LGPD trimestral
- Aprova RIPDs antes de entrada em produção

- Decide recusa fundamentada de direito do titular
- Comunica incidentes à ANPD em até 72 horas
- Assina relatórios de descarte mensal
- Aprova contratos com cláusulas LGPD junto ao Jurídico

12.3 Composição do Comitê LGPD

O Comitê LGPD reúne-se trimestralmente (próximas sessões agendadas: Jul-2026, Out-2026, Jan-2027, Abr-2027 — esta última coincide com revisão anual da política).

Membro	Papel funcional	Tipo de voto
Carla (CFO/Encarregada)	Presidência do Comitê	Decisivo em empate
Bruno (CTO)	Medidas técnicas de segurança	Voto
Lia (Head de Atendimento)	Operação Art. 18 (direitos do titular)	Voto
Jurídico Corporativo — Pinheiro Advogados (fictício, terceirizado)	Avaliação legal e jurisprudencial	Consultivo
RH-Folha — representante	Dados trabalhistas e eSocial	Voto
Auditoria Interna	Compliance e controles	Consultivo
Comunicação Corporativa	Gestão de crises e relação com mídia	Consultivo

Quórum mínimo: presidência + 3 membros com direito a voto.

12.4 Escalações típicas

A cadeia de escalação institucional, do operacional ao estratégico, segue:

- **Diego (Tier 1)** → **Marina (Tier 2)**: requisição padrão Art. 18 ou suspeita de fraude na validação de identidade
- **Marina** → **Lia (Head Atendimento)**: caso de exceção, dado sensível envolvido, prazo SLA em risco, vínculo do titular como colaborador ou fornecedor
- **Lia** → **Carla (Encarregada)**: recusa fundamentada de direito, prazo legal extrapolado, requisição vinda da ANPD, suspeita de incidente
- **Carla** → **Comitê LGPD**: decisão estrutural, mudança de política, sanção administrativa da ANPD recebida, transferência internacional nova

- **Comitê LGPD → CEO + Comitê Executivo**: riscos patrimoniais agudos, decisão de comunicação pública de incidente, mudança de Encarregada

12.5 Conflitos e impedimentos

Membro do Comitê LGPD deve declarar impedimento em deliberação que envolva seu próprio departamento como suspeito de violação. A declaração é feita no início da sessão e registrada em ata. Em caso de impedimento, o membro é substituído pelo suplente nomeado anualmente.

Em caso de impedimento da própria Encarregada (situação rara, ex.: incidente em departamento financeiro sob sua gestão direta como CFO), a Auditoria Interna assume a coordenação ad hoc do Comitê e o Comitê de Auditoria do Conselho de Administração é notificado em até 24 horas.

12.6 Indicadores de desempenho da Encarregada

A atuação da Encarregada é avaliada por KPIs anuais aprovados pelo Comitê Executivo:

- Volume de requisições Art. 18 processadas no SLA: meta ≥95% (Q1-2026 realizado: 97,3%)
- Tempo médio de resolução de requisições: meta ≤12 dias úteis (Q1-2026 realizado: 9 dias úteis)
- Volume de reclamações ANPD recebidas: meta zero (Q1-2026 realizado: zero)
- Incidentes N3+ comunicados à ANPD no prazo: meta 100% (Q1-2026 realizado: N/A, sem N3+)
- Treinamento essencial concluído pela base de colaboradores: meta ≥95% (Q1-2026 realizado: 95,4%)

Página 13 — Treinamento obrigatório e cultura LGPD

13.1 Princípio

O Art. 50, §2º, II da LGPD prevê como boa prática do programa de governança em privacidade a capacitação contínua dos colaboradores. O Apex Group adota programa de treinamento obrigatório anual + treinamentos específicos por função, com conteúdo construído sobre casos reais do HelpSphere.

13.2 Trilhas de treinamento Q2-2026

Trilha	Público	Carga horária	Periodicidade	Última edição
LGPD Essencial	Todos os colaboradores (~8.000)	2 horas EAD	Anual (renovação compulsória)	Q1-2026 (95,4% conclusão)
LGPD para Atendimento (HelpSphere)	Diego + Marina + ~280 atendentes Tier 1/2	4 horas (presencial ou online ao vivo) + simulado Art. 18	Anual	Q2-2026 (em curso)
LGPD para RH-Folha	~45 colaboradores RH	8 horas presencial	Anual	Q1-2026
LGPD Técnica	Bruno (CTO) + ~120 desenvolvedores/SecOps + DPO designados em projetos	16 horas presencial + lab de incident response	Bianual	Q4-2025
LGPD para Liderança	Lia + ~60 gerentes + diretores	6 horas workshop + tabletop exercise simulando comunicação à ANPD	Anual	Q2-2026
LGPD Avançado para Comitê	Carla + Comitê LGPD	24 horas presencial + Curso ANPP + acompanhamento de jurisprudência ANPD	Anual	Q2-2026

13.3 Conteúdo do treinamento essencial

O treinamento essencial de 2 horas obrigatório a todos os colaboradores aborda:

- Conceitos LGPD: dado pessoal, dado sensível, titular, controlador, operador, base legal
- Direitos do titular (Art. 18) e como identificar uma requisição interna escondida em ticket de SAC ou solicitação informal de gestor
- Dados sensíveis e cuidados específicos (segregação clínica, vedação de discussão informal)
- Princípio do menor privilégio no acesso a sistemas
- Identificação e reporte de incidentes (o que constitui incidente, como reportar, prazo)

- Canal de denúncia LGPD: `compliance@apex.com.br` e canal anônimo no portal

13.4 Treinamento de atendentes — referência a casos reais

O material didático da trilha de atendimento é construído sobre tickets âncora do HelpSphere, com cenários que os atendentes efetivamente encontram. Casos incluídos:

- **TKT-17** (Apex Tech, reset SSO Entra ID em massa) — ilustra ciclo de credencial, MFA, princípio do menor privilégio, e diferença entre service principal e Managed Identity (com lição arquitetural). Diego e Marina aprendem a identificar requisições de reset legítimas vs tentativas de engenharia social.
- **TKT-31** (Apex Mercado, gestação de risco em turno noturno) — workflow de troca de turno preservando confidencialidade clínica; o que o atendente pode e não pode saber, como escalar para RH sem expor detalhes na fila aberta.
- **TKT-33** (Apex Moda, banco de horas 142h excedendo CCT SP) — quando dado trabalhista é tema de ticket, qual o tratamento LGPD, quem acessa o histórico de banco de horas, retenção 30 anos.
- **TKT-35** (Apex Logística, CAT por acidente em descarga) — comunicação obrigatória do acidente no eSocial, dado sensível de saúde, e o que o atendente registra no ticket vs o que vai para SOC.
- **TKT-39** (Apex Casa, denúncia anônima sobre supervisor Berrini) — canal de ética sob LGPD, sigilo, prazo de 30 dias, direito ao contraditório do denunciado após etapa instrutória.

13.5 Avaliação e certificação

- Avaliação ao fim de cada trilha: nota mínima de aprovação 70/100
- Não conclusão da trilha essencial dentro do prazo anual: bloqueio de bonificação anual + plano de ação individual com gestor direto, prazo de 30 dias para regularização
- Certificados de conclusão arquivados no TOTVS RM com retenção de 5 anos
- Renovação anual da trilha essencial sempre no Q2 (sincronizado com revisão da política)

13.6 Cultura — comunicação contínua

Além do treinamento formal, o Apex Group mantém comunicação contínua:

- **Newsletter trimestral "LGPD na Prática"** distribuída por e-mail corporativo, com case do trimestre + dica operacional + mudanças regulatórias da ANPD
- **Cartazes físicos nas lojas** Apex Mercado, Apex Tech, Apex Moda e Apex Casa, ao lado dos avisos NR-26 obrigatórios, informando direitos do titular e canal de contato da Encarregada

- **Tela inicial dos PDVs Apex Tech** em modo programa-piloto biométrico exibe micro-aviso de tratamento de imagem facial (Página 6.2)
- **Treinamento de onboarding** obrigatório no primeiro dia útil de cada novo colaborador, antes da liberação de acesso a sistemas
- **Comunicado interno em caso de incidente** N2+ — todo colaborador relevante recebe nota com lição aprendida e mudança de processo aplicada

13.7 Métricas de cultura LGPD

A Encarregada acompanha indicadores de cultura semestralmente:

- Taxa de conclusão da trilha essencial (meta ≥95%; realizado Q1-2026: 95,4%)
- Pulse survey de percepção LGPD: ≥80% concordam que "sei o que fazer se receber requisição de Art. 18" (Q1-2026: 84%)
- Volume de reportes voluntários de quase-incidente: meta crescente (Q1-2026: 28 reportes voluntários)
- Tempo médio entre detecção interna e reporte ao Comitê LGPD: meta ≤24h (Q1-2026: 14h)

Página 14 — Acessos, credenciais e revogação

14.1 Princípio do menor privilégio

Todo acesso a sistemas que tratem dados pessoais pelo Apex Group segue quatro princípios complementares:

- **Necessidade-de-saber (need-to-know):** acesso somente ao escopo de dados necessário à função; gestor de loja não acessa folha de outras lojas, RH-Folha de uma marca não acessa dados de outra marca exceto em ações intra-grupo formais
- **Privilégio mínimo:** permissão padrão é leitura; escrita só com justificativa documentada e aprovação do gestor direto; permissão administrativa só para perfis específicos com revisão trimestral
- **Segregação de funções:** quem aprova ≠ quem executa ≠ quem audita; nenhum perfil acumula as três responsabilidades em mesma operação crítica
- **Revisão periódica de acessos:** trimestral pelo gestor direto + anual pela Auditoria Interna, com remoção automática de acessos não revalidados

14.2 Identidade corporativa — Microsoft Entra ID

Toda autenticação corporativa Apex Group passa por Microsoft Entra ID (anteriormente Azure Active Directory), com as seguintes salvaguardas:

- **MFA obrigatório** para 100% dos colaboradores e terceirizados com acesso a dados pessoais (cobertura Q1-2026: 99,7%, com 0,3% em processo de regularização)
- **Conditional Access** com regras de bloqueio para acessos a partir de IP externo + dispositivo não-gerenciado
- **Sign-in risk policy** com bloqueio automático em risk score "alto" e desafio MFA adicional em risk score "médio"
- **Rotação mensal de senhas** para perfis administrativos (não rotativa para usuários comuns com MFA, conforme NIST 800-63B revisado)
- **Passwordless** (FIDO2 ou Windows Hello) em piloto para 200 colaboradores de TI no Q2-2026, com expansão prevista para Q4-2026

14.3 Caso âncora — TKT-17 (Reset SSO em massa)

No primeiro trimestre de 2026, a política mensal de password rotation do Entra ID derivou em incidente operacional: 12 colaboradores da matriz não receberam o e-mail de reset agendado, e a primeira tentativa de login pós-rotação falhou com erro de credencial inválida.

Investigação técnica: A causa-raiz foi identificada pelo time de SecOps de Bruno em 4 horas. O script de notificação que envia o e-mail de reset autenticava-se em Microsoft Graph API usando um **service principal** com client secret rotacionado mensalmente. A última rotação encontrou rate-limit de hard cap na API de gestão de credenciais do Entra (quota daily), o que fez o script cair antes de processar a notificação para os 12 últimos colaboradores da fila.

Resolução imediata: 1. Senha aplicada manualmente para os 12 colaboradores afetados pelo SecOps via processo de identity verification reforçado (validação por gestor direto + canal seguro) 2. Acesso restaurado em até 2 horas pós-detecção 3. Comunicação proativa aos 12 colaboradores com explicação do incidente e canal exclusivo para dúvidas

Resolução arquitetural (a lição): 4. Script de notificação reescrito para usar **Managed Identity** em vez de service principal com client secret. Managed Identity não requer rotação manual de credencial e não está sujeita ao rate-limit que afetou o service principal. 5. Postmortem documentado e revisão de outros scripts equivalentes em ambientes Apex Group — eliminação de secrets em texto claro em pipelines, migração progressiva para Managed Identity como padrão 6. Decisão arquitetural cravada por Bruno como padrão Apex Group para todo automation interno que precise acessar APIs Microsoft: **Managed Identity primeiro, service principal apenas em casos com justificativa documentada**

Aprendizado LGPD: O uso de Managed Identity reduz drasticamente a superfície de ataque sobre credenciais que dão acesso a sistemas com dados pessoais. Service principal com secret rotativo é vetor de risco em três frentes: vazamento do secret, falha de rotação (como ocorrido), e dificuldade de auditoria de uso. Managed Identity elimina as duas primeiras frentes e simplifica a terceira.

O caso TKT-17 foi classificado N2 conforme escala da Página 11.2 (falha técnica com exposição limitada e sem comprometimento de dado pessoal sensível) e gerou postmortem público interno conforme prática descrita em 11.6.

14.4 Procedimento de revogação de acesso

A revogação de acesso é disparada em quatro hipóteses, cada uma com fluxo automatizado:

- **Desligamento** (eSocial S-2299 transmitido) — revogação automática em até 24 horas via integração TOTVS RM ↔ Entra ID, com remoção de associação de grupo, revogação de tokens ativos e bloqueio de licença Microsoft 365
- **Transferência de função** — revisão de acessos em até 5 dias úteis pelo novo gestor; acessos do papel anterior são mantidos por 30 dias em modo somente-leitura para handoff e então revogados
- **Suspensão disciplinar** — revogação imediata pelo RH em coordenação com SecOps, com restauração manual apenas após decisão formal de retorno
- **Suspeita de incidente** — bloqueio preventivo pelo CTO antes de qualquer apuração formal, com prazo máximo de 5 dias úteis para conclusão da triagem; após esse prazo, decisão de manter bloqueio é submetida ao Comitê LGPD

14.5 Auditoria de acesso a dados sensíveis

Acessos a dados sensíveis recebem tratamento auditável reforçado:

- **Logs imutáveis** em Azure Blob com retenção legal (Immutable Storage com policy de 20 anos para PCMSO, 30 anos para eSocial)
- **Revisão trimestral pelo Comitê LGPD** com sample aleatório de 5% dos acessos ao prontuário SOC, CAT, dados de menores e biometria PDV
- **Alerta automático** para Bruno + Carla em acessos fora do horário comercial (>22h ou <6h) e em acessos de pessoa diferente da cadeia de papel esperada
- **Justificativa obrigatória** para acessos do Comitê de Ética a dados de colaborador sob investigação (caso TKT-39)

14.6 Validação de identidade do titular (não-colaborador)

A validação de identidade do titular que requisita Art. 18 (Página 4.2) segue procedimento próprio:

- Cruzamento mínimo de 3 dados: CPF + endereço + e-mail, ou CPF + número de pedido anterior + telefone cadastrado
- Em caso de dúvida ou 2 tentativas falhas, Marina conduz vídeo-confirmação por canal seguro (Microsoft Teams convite por e-mail cadastrado), com captura de print do RG ou CNH sem armazenamento da imagem
- Em caso de 3 tentativas falhas, requisição é recusada com notificação à Encarregada e instrução ao titular para presença física em loja Apex+ com documento original

A política equilibra acessibilidade (cliente legítimo consegue exercer direito) e proteção (terceiro mal-intencionado não consegue exercer direito alheio).

Página 15 — Anexos, contatos e footer

15.1 Modelo simplificado — Termo de Consentimento (newsletter marketing)

```
 TERMO DE CONSENTIMENTO LGPD — COMUNICAÇÃO COMERCIAL APEX GROUP

Eu, [NOME COMPLETO], CPF [XXX.XXX.XXX-XX], autorizo o Apex Group
Participações S.A. (CNPJ 12.345.678/0001-90) a tratar meus dados
pessoais para envio de comunicações comerciais, promoções e novidades
das marcas Apex Mercado, Apex Tech, Apex Moda e Apex Casa, por meio
de e-mail, SMS, push notification e WhatsApp Business.

Finalidade: comunicação comercial personalizada com base em histórico
de compra e perfil declarado.

Base legal: Art. 7, I da Lei 13.709/2018 — consentimento.

Compartilhamento: meus dados não são compartilhados com terceiros para
fins comerciais externos. Compartilhamento intra-grupo Apex está
descrito em `privacidade.apex.com.br/transparencia`.

Retenção: enquanto o consentimento estiver vigente. Revogável a
qualquer momento em `privacidade.apex.com.br/preferencias` ou e-mail
`dpo@apex.com.br`. A revogação é processada em até 24 horas.

Direitos garantidos: confirmação, acesso, correção, eliminação,
portabilidade, oposição, revogação (Art. 18 LGPD).

Encarregada de Proteção de Dados: Carla — `dpo@apex.com.br`.

[ ] Li, compreendi e concordo expressamente com o tratamento descrito.

Data: ___/___/______      Assinatura: ____________________
```

15.2 Modelo simplificado — Termo de Consentimento Biometria PDV (Apex Tech)

```
 TERMO DE CONSENTIMENTO LGPD — BIOMETRIA FACIAL APEX TECH

Eu, [NOME COMPLETO], CPF [XXX.XXX.XXX-XX], autorizo o Apex Tech
(marca controlada por Apex Group Participações S.A., CNPJ
12.345.678/0001-90) a coletar minha imagem facial nas lojas-conceito
Iguatemi, Morumbi, Faria Lima, Berrini, JK Iguatemi, Pátio
Higienópolis, Eldorado e Cidade Jardim, exclusivamente para
identificação personalizada como cliente Apex+ e prevenção a perdas.

Finalidades específicas:
1. Reconhecer minha entrada na loja para acionar minha experiência
   personalizada Apex+ (saldo de pontos, ofertas dirigidas)
2. Apoiar a equipe de prevenção a perdas em correlação com
   ocorrências registradas em meu próprio nome

Base legal: Art. 11, I da Lei 13.709/2018 — consentimento específico
e destacado para tratamento de dado pessoal sensível biométrico.

Tratamento técnico: minha imagem facial é convertida em hash
criptográfico (embedding facial). A imagem original NÃO é armazenada.
O hash é mantido em Azure Key Vault com criptografia AES-256.

Retenção: 90 dias para perfilamento. Revogação tem efeito imediato
com eliminação do hash.

Compartilhamento: VEDADO. Biometria não é repassada a nenhum terceiro.

Transferência internacional: VEDADA. Todo o processamento ocorre em
território brasileiro (região Azure Brasil Sul).

Direitos garantidos: confirmação, acesso, eliminação, revogação
(Art. 18 LGPD).

Canal específico de revogação: `privacidade.apex.com.br/biometria`
ou `dpo@apex.com.br`.

[ ] Li, compreendi e concordo expressamente com o tratamento
    biométrico descrito.

Data: ___/___/______      Assinatura: _____________________
```

15.3 Contatos LGPD Apex Group

Contato	Canal	Quando usar
Encarregada (DPO) Apex Group	`dpo@apex.com.br`	Requisição Art. 18, dúvida sobre tratamento, exercício de direitos do titular
Compliance LGPD interno	`compliance@apex.com.br`	Reporte de incidente, denúncia interna, dúvida operacional
Portal LGPD do titular	`privacidade.apex.com.br/titular`	Self-service de direitos do titular
Comitê de Ética	`etica@apex.com.br` + canal anônimo no portal	Denúncia ética (LGPD + Código de Conduta)
HelpSphere SAC	Chat WhatsApp Business / 0800 / chat site	Atendimento geral com escalonamento LGPD
Imprensa e relações públicas	`imprensa@apex.com.br`	Posicionamento institucional sobre incidente público

15.4 Contatos ANPD (Autoridade Nacional de Proteção de Dados)

- **Site oficial:** `www.gov.br/anpd`
- **Endereço:** Esplanada dos Ministérios, Bloco C, 6º andar — Brasília/DF — CEP 70046-900
- **E-mail institucional:** `anpd@anpd.gov.br`
- **Peticionamento eletrônico:** `www.gov.br/anpd/pt-br/canais_atendimento/peticionamento`
- **Comunicação de incidente:** formulário oficial via sistema da ANPD conforme Resolução CD/ANPD nº 15/2024
- **Canal de denúncia do titular contra controlador:** disponível em `www.gov.br/anpd/pt-br/canais_atendimento`

15.5 Referências normativas consolidadas

- **Lei 13.709/2018** — LGPD (texto consolidado: `www.planalto.gov.br`)
- **Decreto 10.474/2020** — Estrutura ANPD

- **Resoluções CD/ANPD vigentes Q2-2026:** nº 1/2021 (regulamento interno), nº 2/2022 (pequeno porte), nº 4/2023 (dosimetria de sanções), nº 15/2024 (incidentes)
- **Marco Civil da Internet** — Lei 12.965/2014
- **CDC** — Lei 8.078/1990
- **CLT** — Decreto-Lei 5.452/1943
- **eSocial** — Decreto 8.373/2014 e Portarias Conjuntas RFB/INSS/MTb
- **Empresa Cidadã** — Lei 11.770/2008
- **FGTS** — Lei 8.036/1990 e Decreto 99.684/1990
- **NR-7 (PCMSO)** — Portaria SSST nº 24/1994 e atualizações MTE
- **Acidente do trabalho** — Lei 8.213/1991
- **Aprendizagem** — Lei 10.097/2000 e Decreto 9.579/2018

15.6 Cross-references com outros documentos Apex Group

Esta política conversa com os demais documentos normativos do conjunto sample-kb Apex Group:

- `manual_operacao_loja_v3.pdf` (Operacional, 47 páginas) — procedimentos de loja que tocam dados pessoais (cadastro de cliente em PDV, programa fidelidade, recebimento de mercadoria com dados de transportadora)
- `runbook_sap_fi_integracao.pdf` (TI, 22 páginas) — integração ERP↔SEFAZ com compartilhamento fiscal sob obrigação legal
- `faq_pedidos_devolucao.pdf` (Comercial, 12 páginas) — dados em devolução B2C, retenção pela relação de consumo CDC
- `politica_reembolso_lojista.pdf` (Financeiro, 8 páginas) — dados financeiros de lojista B2B
- `manual_pos_funcionamento.pdf` (Operacional, 35 páginas) — tratamento de dados em PDV NFC-e, tokenização Cielo
- `runbook_problemas_rede.pdf` (TI, 18 páginas) — incidente técnico com potencial de virar incidente LGPD
- `faq_horario_atendimento.pdf` (Comercial, 4 páginas) — janelas de atendimento para exercício de Art. 18

15.7 Histórico de versões

Versão	Data	Mudanças principais	Aprovação
v1.0	Q3-2020	Versão inicial pós-vigência LGPD	Comitê Executivo
v2.0	Q3-2021	Inclusão de sanções administrativas (vigência Art. 52)	Comitê Executivo
v3.0	Q2-2023	Acumulação Carla CFO/DPO; criação Comitê LGPD multidisciplinar	Comitê Executivo + Conselho
v3.5	Q2-2024	Programa-piloto biométrico Apex Tech; RIPD específico	Comitê LGPD
v4.0	Q2-2025	Resolução CD/ANPD nº 4/2023 (dosimetria) incorporada	Comitê LGPD
v4.1	Q4-2025	Resolução CD/ANPD nº 15/2024 (incidentes) incorporada	Comitê LGPD
v4.2	**Q2-2026**	**Revisão anual; integração de casos TKT-17 e TKT-31 a 40 no treinamento; refino da Página 9 sobre transferência internacional**	**Comitê Executivo + Comitê LGPD**

15.8 Footer

Versão `v4.2` · Aprovado pelo Comitê Executivo Apex Group em sessão de `Q2-2026` · Próxima revisão obrigatória `Q2-2027` · Documento confidencial — uso interno Apex Group.

Cópia controlada disponível em `intranet.apex.com.br/politicas/lgpd-v4.2`.

Em caso de divergência entre cópias, prevalece a versão controlada do repositório jurídico sob custódia da Encarregada.

Encarregada de Proteção de Dados Apex Group:

Carla — CFO acumulando função de Encarregada (DPO) `dpo@apex.com.br`